

Procedura obsługi incydentów bezpieczeństwa i incydentów operacyjnych

Bank Przykładowy S.A., BP/PRO/07, wersja 1, obowiązuje od 1 listopada 2022 r. do 29 lutego 2024 r.

Oznaczenie	BP/PRO/07
Wersja	1
Właściciel	Departament Bezpieczeństwa
Zatwierdził	Zarząd Banku Przykładowego S.A.
Data zatwierdzenia	11 października 2022 r.
Obowiązuje od	1 listopada 2022 r.
Obowiązuje do	29 lutego 2024 r.

Historia zmian

Wersja	Data	Opis zmian
1	11 października 2022 r.	Wydanie pierwsze.

1. Cel

Celem procedury jest zapewnienie jednolitego, szybkiego i udokumentowanego sposobu postępowania w przypadku wystąpienia w Banku incydentu bezpieczeństwa lub incydentu operacyjnego, tak aby zminimalizować jego skutki dla Klientów, ciągłości działania Banku i bezpieczeństwa chronionych informacji.

Procedura określa w szczególności:

- 1) źródła zgłoszeń o incydentach oraz sposób ich przyjmowania w Rejestrze;
- 2) zasady klasyfikacji incydentów i nadawania im poziomu ważności;
- 3) skład i zadania Zespołu oraz podział ról w trakcie obsługi incydentu;
- 4) działania mające na celu ograniczenie rozprzestrzeniania się incydentu i usunięcie jego przyczyn;
- 5) zasady komunikacji z Klientami, z organem nadzoru oraz z podmiotami zewnętrznymi;
- 6) terminy zgłaszania incydentów poważnych oraz naruszeń ochrony danych osobowych;
- 7) zabezpieczanie materiału dowodowego, przywracanie działania usług i przegląd po incydencie;
- 8) zasady testowania procedury i prowadzenia ćwiczeń.

Procedura służy także realizacji obowiązków Banku wynikających z przepisów o usługach płatniczych, Prawa bankowego oraz przepisów o ochronie danych osobowych, a także

wymogów organu nadzoru w zakresie zarządzania ryzyka operacyjnego i ryzyka technologicznego.

2. Zakres stosowania

Procedurę stosuje się do każdego incydentu, który wpływa na systemy informatyczne, procesy, dane, lokale lub pracowników Banku. Dotyczy to także incydentów powstałych po stronie dostawców usług zewnętrznych, jeżeli wywołują one skutki w działalności Banku.

Procedura obejmuje incydenty następujących rodzajów:

- 1) incydenty bezpieczeństwa informacji, w szczególności:
 - a) nieuprawniony dostęp do systemów, danych lub rachunków Klientów;
 - b) złośliwe oprogramowanie, w tym oprogramowanie szysfrujące dane w celu wymuszenia okupu;
 - c) ataki typu odmowa usługi na kanały elektroniczne Banku;
 - d) wyłudzenie danych uwierzytelniających Klientów lub pracowników (phishing, vishing, smishing);
- 2) incydenty operacyjne, w szczególności:
 - a) awarie systemów centralnych, w tym systemu centralnego CBS-PRZYKŁAD, oraz systemów rozliczeniowych;
 - b) niedostępność bankowości elektronicznej, bankomatów lub terminali płatniczych;
 - c) błędy w przetwarzaniu transakcji prowadzące do nieprawidłowych obciążeń lub uznań rachunków;
 - d) niedostępność kluczowych dostawców lub podwykonawców;
- 3) incydenty związane z bezpieczeństwem fizycznym, jeżeli mogą skutkować utratą informacji lub środków Klientów;
- 4) naruszenia ochrony danych osobowych.

Procedura obowiązuje wszystkich pracowników Banku, osoby świadczące pracę na podstawie umów cywilnoprawnych oraz pracowników podmiotów zewnętrznych, którzy mają dostęp do systemów lub danych Banku. Obowiązek zgłoszenia incydentu dotyczy każdej z tych osób, niezależnie od zajmowanego stanowiska.

Procedury nie stosuje się do rutynowych zgłoszeń serwisowych niewpływających na bezpieczeństwo lub ciągłość działania, które obsługuje się w trybie wsparcia użytkowników. Reklamacje Klientów rozpatruje się według odrębnych zasad; jeżeli reklamacja ujawnia incydent, pracownik postępuje zgodnie z niniejszą procedurą.

3. Podstawy prawne i dokumenty powiązane

Procedurę opracowano na podstawie przepisów powszechnie obowiązujących oraz regulacji wewnętrznych Banku.

1. Z przepisów powszechnie obowiązujących szczególne znaczenie mają:
 - 1) obowiązki dostawców usług płatniczych w zakresie bezpieczeństwa i zgłaszania

poważnych incydentów określa ustawa z dnia 19 sierpnia 2011 r. o usługach płatniczych (Dz. U. 2024 poz. 30);

- 2) wymogi dotyczące zarządzania ryzykiem, kontroli wewnętrznej i ciągłości działania banków wynikają z przepisów prawa bankowego — zob. ustawa z dnia 29 sierpnia 1997 r. – Prawo bankowe (Dz. U. 2024 poz. 1646);
 - 3) zasady postępowania w razie naruszenia ochrony danych osobowych określa ustawa z dnia 10 maja 2018 r. o ochronie danych osobowych (Dz. U. 2019 poz. 1781) oraz rozporządzenie Parlamentu Europejskiego i Rady (UE) 2016/679.
2. Dokumenty wewnętrzne, z którymi procedura jest powiązana, to:
- 1) polityka bezpieczeństwa informacji Banku;
 - 2) plan ciągłości działania oraz plany awaryjnego odtwarzania systemów;
 - 3) instrukcja zarządzania uprawnieniami i dostępem do systemów;
 - 4) procedura obsługi reklamacji Klientów;
 - 5) procedura obsługi wniosków osób, których dane dotyczą.

W razie rozbieżności między procedurą a przepisami powszechnie obowiązującymi lub wytycznymi organu nadzoru stosuje się te przepisy lub wytyczne, a właściciel procedury niezwłocznie wszczyna tryb jej zmiany.

4. Odpowiedzialności

Za obsługę incydentów w Banku odpowiadają jednostki i osoby wymienione poniżej. Zakres ich zadań dotyczy każdej fazy obsługi incydentu: od wykrycia po przegląd końcowy. Zadania pozostałych jednostek opisano w dalszych częściach procedury.

1. **Pracownik** każdej jednostki Banku:
 - 1) zgłasza każde zauważone zdarzenie wskazujące na incydent w terminie 30 minut od jego zauważenia;
 - 2) nie podejmuje na własną rękę działań naprawczych, które mogłyby zniekształcić ślady incydentu;
 - 3) stosuje się do poleceń Zespołu wydanych w trakcie obsługi incydentu.
2. **Kierownik jednostki organizacyjnej:**
 - 1) zapewnia znajomość procedury wśród podległych pracowników, w tym przeszkolenie nowych pracowników w terminie 30 dni od zatrudnienia;
 - 2) wyznacza osobę kontaktową do spraw incydentów w swojej jednostce;
 - 3) udostępnia pracowników i zasoby potrzebne do obsługi incydentu.
3. **Departament Bezpieczeństwa**, jako właściciel procedury:
 - 1) prowadzi Rejestr i nadzoruje jego kompletność;
 - 2) kieruje pracami Zespołu i wyznacza kierownika incydentu;
 - 3) dokonuje klasyfikacji incydentów i zatwierdza zmianę ich poziomu ważności;
 - 4) przygotowuje zawiadomienia dla organu nadzoru i koordynuje współpracę z zespołem CSIRT;
 - 5) odpowiada za aktualność procedury, testy i ćwiczenia.

4. **Departament Informatyki** odpowiada za techniczną obsługę incydentu: izolowanie systemów, analizę techniczną, usunięcie przyczyn i przywrócenie działania usług, a także za zabezpieczanie logów i obrazów systemów.
5. **Departament Zgodności** ocenia, czy incydent wymaga zawiadomienia organu nadzoru, opiniuje treść zawiadomień i monitoruje realizację zaleceń po incydencie.
6. **Inspektor Ochrony Danych** ocenia, czy incydent stanowi naruszenie ochrony danych osobowych, określa ryzyko dla osób, których dane dotyczą, oraz opracowuje zgłoszenie do organu ochrony danych i powiadomienia osób zainteresowanych.

Dostawcy usług zewnętrznych są obowiązani w umowach do niezwłocznego informowania Banku o incydentach, które dotyczą świadczonych usług lub danych Banku, oraz do współpracy w ich wyjaśnieniu. Umowy powinny wskazywać:

- 1) maksymalny czas przekazania informacji o incydencie;
- 2) osobę lub kanał kontaktowy dostępny całodobowo;
- 3) obowiązek udostępnienia logów i raportu z analizy przyczyn;
- 4) prawo Banku do przeprowadzenia kontroli u dostawcy po incydencie.

Za nadzór nad realizacją tych obowiązków jest odpowiedzialny właściciel umowy z dostawcą wskazany w rejestrze umów Banku.

Właściciel systemu lub procesu odpowiada za to, aby dla jego systemu lub procesu istniały aktualne: opis zależności od innych systemów, dane kontaktowe dostawców i administratorów, instrukcja awaryjnego zatrzymania i uruchomienia oraz opis dopuszczalnego czasu niedostępności. Właściciel potwierdza te informacje raz w roku na prośbę Jednostki bezpieczeństwa.

Administrator systemu wykonuje czynności techniczne powierzone przez kierownika incydentu, rejestruje wszystkie wykonane operacje (z godziną i identyfikatorem konta) i nie dokonuje zmian poza zakresem zlecenia.

Jednostka komunikacji (Biuro Komunikacji Korporacyjnej) przygotowuje komunikaty dla Klientów, mediów i pracowników, uzgodnione z kierownikiem incydentu, a w sprawach prawnych — także z Jednostką prawną. Jednostka komunikacji jest jedynym podmiotem uprawnionym do kontaktu z mediami w sprawie incydentu.

Jednostka obsługi klienta (Departament Obsługi Klienta) przekazuje Klientom uzgodnione komunikaty, zbiera zgłoszenia Klientów dotyczące incydentu i przekazuje kierownikowi incydentu zbiorcze informacje o ich liczbie i charakterze, nie rzadziej niż w odstępach ustalonych w raporcie stanu.

Dyżurny Jednostki bezpieczeństwa pełni dyżur całodobowo, w tym w dni ustawowo wolne od pracy, i jest pierwszym punktem kontaktu dla zgłoszeń pod numerem 800 000 040 i na adres incydenty@bank.example. Dyżurny:

- 1) przyjmuje i rejestruje zgłoszenia, dokonuje wstępnej klasyfikacji i uruchamia dalsze kroki procedury;
- 2) prowadzi listę kontaktów alarmowych i sprawdza jej aktualność co kwartał;
- 3) przekazuje dyżur następnej osobie w sposób udokumentowany, ze wskazaniem

trwających incydentów.

Jednostka kadr (Departament Zasobów Ludzkich) bierze udział w obsłudze incydentów, w których zachodzi podejrzenie nieprawidłowego działania pracownika, prowadzi postępowania wyjaśniające zgodnie z przepisami prawa pracy i zapewnia, aby czynności wobec pracownika nie naruszały jego praw.

Jednostka audytu (Departament Audytu Wewnętrznego) niezależnie ocenia, czy procedura jest stosowana prawidłowo i czy jej postanowienia są adekwatne do ryzyka. Nie uczestniczy w bieżącej obsłudze incydentów, aby zapewnić niezależność.

5. Definicje

Użyte w procedurze określenia oznaczają:

- 1) **Bank** — Bank Przykładowy S.A.;
- 2) **Klient** — osoba, która zamierza korzystać z produktów lub usług Banku;
- 3) **Pracownik** — osoba zatrudniona w Banku, realizująca czynności objęte procedurą;
- 4) **Właściciel procedury** — komórka organizacyjna odpowiedzialna za jej aktualność i stosowanie;
- 5) **Dzień roboczy** — dzień od poniedziałku do piątku, z wyłączeniem dni ustawowo wolnych od pracy;
- 6) **Trwały nośnik** — nośnik umożliwiający zachowanie informacji w sposób dostępny do późniejszego wykorzystania;
- 7) **Placówka** — jednostka Banku obsługująca Klientów;
- 8) **Infolinia** — telefoniczny punkt obsługi Klientów, numer 800 000 001;
- 9) **Eskalacja** — przekazanie sprawy do jednostki lub osoby o wyższych uprawnieniach decyzyjnych.

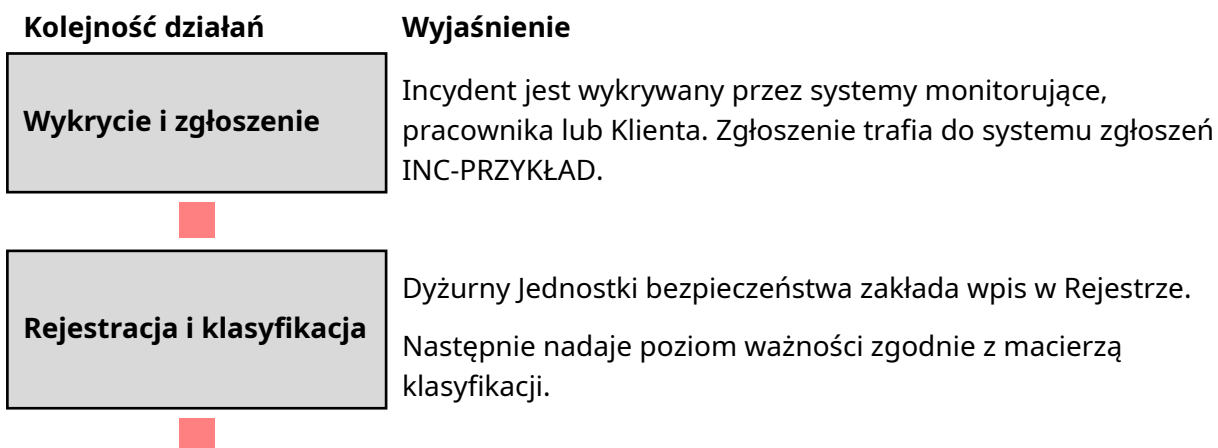
Na potrzeby procedury przyjmuje się dodatkowo następujące określenia:

- 1) **Incydent** — zdarzenie, które godzi w poufności, integralności lub dostępności informacji albo ciągłości działania usług, bądź jest uznawane o spowodowanie takiego naruszenia;
- 2) **Incydent bezpieczeństwa** — incydent związany z nieuprawnionym lub nieprawidłowym działaniem wobec informacji, systemów lub osób;
- 3) **Incydent operacyjny** — incydent wynikający z awarii, błędu lub zakłócenia procesów, systemów albo dostawców, niebędący działaniem celowym;
- 4) **Incydent poważny** — incydent o poziomie ważności krytycznym lub wysokim, spełniający kryteria zgłoszenia organowi nadzoru;
- 5) **Organ nadzoru** — organ nadzoru właściwy dla Banku, któremu przekazuje się zawiadomienia o incydentach poważnych;
- 6) **CSIRT** — zespół CSIRT właściwy dla sektora finansowego, z którym Bank wymienia informacje o zagrożeniach;
- 7) **Naruszenie ochrony danych osobowych** — naruszenie bezpieczeństwa prowadzące do przypadkowego lub bezprawnego zniszczenia, utraty, zmiany, nieuprawnionego ujawnienia danych osobowych lub dostępu do nich;

- 8) **Kierownik incydentu** — osoba wyznaczona przez Jednostkę bezpieczeństwa, która koordynuje obsługę konkretnego incydentu;
- 9) **Zespół** — Zespół Reagowania na Incydenty, złożony z przedstawicieli jednostek wskazanych w procedurze i powoływany do obsługi incydentów o poziomie wysokim i krytycznym;
- 10) **Rejestr** — centralny rejestr incydentów o nazwie RINC, prowadzony w systemie zgłoszeń INC-PRZYKŁAD;
- 11) **System SIEM** — system monitorowania zdarzeń SIEM-PRZYKŁAD, który zbiera i koreluje zdarzenia z systemów informatycznych;
- 12) **Pokój operacyjny** — wirtualny pokój operacyjny incydentu, w którym prowadzi się dziennik zdarzeń i wymianę ustaleń podczas obsługi incydentu;
- 13) **Jednostka bezpieczeństwa** — Departament Bezpieczeństwa; **Jednostka informatyki** — Departament Informatyki; **Jednostka zgodności** — Departament Zgodności; **Jednostka operacji** — Departament Operacji; **Jednostka prawna** — Departament Prawny;
- 14) **Jednostka komunikacji** — Biuro Komunikacji Korporacyjnej; **Jednostka obsługi klienta** — Departament Obsługi Klienta; **Jednostka ciągłości** — Biuro Ciągłości Działania; **Jednostka ryzyka** — Departament Ryzyka; **Jednostka audytu** — Departament Audytu Wewnętrznego; **Jednostka kadr** — Departament Zasobów Ludzkich;
- 15) **Inspektor** — Inspektor Ochrony Danych; **Zarząd** — Zarząd Banku;
- 16) **Ograniczenie skutków** — działania zatrzymujące rozprzestrzenianie się incydentu bez usuwania jego przyczyny;
- 17) **Materiał dowodowy** — logi, obrazy dysków, zapisy rozmów, wiadomości i inne dane, które mogą służyć ustaleniu przebiegu incydentu;
- 18) **RTO i RPO** — odpowiednio maksymalny akceptowalny czas przywrócenia usługi oraz maksymalna akceptowalna utrata danych, określone w planie ciągłości działania.

6. Opis postępowania — wykrywanie i rejestracja incydentu

Poniższy schemat przedstawia podstawowy przebieg obsługi incydentu. Szczegółowe zasady dla poszczególnych etapów opisano w dalszej części procedury.



Kolejność działań	Wyjaśnienie
Ograniczenie skutków	Zespół zatrzymuje rozprzestrzenianie się incyduentu i zabezpiecza ślady.
Komunikacja i raportowanie	Informowani są Klienci, kierownictwo, organ nadzoru oraz inne uprawnione podmioty w terminach określonych procedurą.
Usunięcie i przywrócenie	Usuwa się przyczynę incyduentu i przywraca działanie usług według priorytetów ciągłości działania.
Przegląd i wnioski	Po zamknięciu incyduentu przeprowadza się przegląd, a zalecenia wprowadza do planu działań.

6.1. Źródła wykrywania. Incydenty identyfikuje się na podstawie następujących źródeł:

- 6.1.1. alertów systemu SIEM (SIEM-PRZYKŁAD), który koreluje zdarzenia z systemów informatycznych, zapór sieciowych, systemów antywirusowych i systemów kontroli dostępu;
- 6.1.2. zgłoszeń pracowników przekazywanych przez system zgłoszeń INC-PRZYKŁAD, telefonicznie pod numerem dyżurnym 800 000 040 lub pocztą elektroniczną na adres incydenty@bank.example;
- 6.1.3. zgłoszeń Klientów przyjmowanych na infolinii 800 000 001, w placówkach i w reklamacjach;
- 6.1.4. komunikatów dostawców zewnętrznych, partnerów rozliczeniowych, zespołu CSIRT oraz organu nadzoru;
- 6.1.5. wyników kontroli, audytów, testów penetracyjnych i monitoringu transakcji pod kątem nadużyć.

6.2. Zgłoszenie przez pracownika. Pracownik, który zauważy zdarzenie mogące być incyduentem, zgłasza je w terminie 30 minut od jego zauważenia.

- 6.2.1. Zgłoszenie obejmuje opis zdarzenia, czas jego zauważenia, nazwę systemu lub procesu, liczbę i rodzaj podejrzanych operacji oraz dane osoby zgłaszającej; wzór zgłoszenia stanowi formularz F-BEZ-01.
- 6.2.2. Jeżeli zdarzenie może mieć skutki krytyczne (np. niedostępność systemu centralnego, wyciek danych, podejrzenie przejęcia kont uprzywilejowanych), pracownik najpierw dzwoni na numer dyżurny, a dopiero potem uzupełnia formularz.
- 6.2.3. Pracownik zachowuje wiadomość, plik lub zrzut ekranu, które wzbudziły podejrzenie, i nie przekazuje ich dalej poza kanały służbowe.

6.3. Przyjęcie zgłoszenia. Dyżurny Jednostki bezpieczeństwa przyjmuje zgłoszenie w systemie zgłoszeń, niezwłocznie potwierdza jego przyjęcie osobie zgłaszającej i weryfikuje kompletność zgłoszenia.

- 6.3.1. Gdy zgłoszenie jest niekompletne, dyżurny uzupełnia je w rozmowie z osobą zgłaszającą, nie wstrzymując rejestracji.
- 6.3.2. Zgłoszenia wielokrotne dotyczące tego samego zdarzenia łączy się w jeden wpis, zachowując ich historię.
- 6.4. Rejestracja incydentu. Dyżurny zakłada wpis w Rejestrze i przypisuje mu unikalny numer. Do wpisu wprowadza się co najmniej:
 - 6.4.1. datę i godzinę wykrycia oraz zgłoszenia, a także źródło informacji;
 - 6.4.2. opis zdarzenia i systemy lub procesy, których dotyczy;
 - 6.4.3. wstępną ocenę skutków, w tym liczbę Klientów i wartość operacji objętych incydem;
 - 6.4.4. imię i nazwisko osoby odpowiedzialnej za dalszą obsługę oraz kartę incydentu według formularza F-BEZ-02.
- 6.5. Wstępna weryfikacja. Dyżurny sprawdza w ciągu kilkunastu minut, czy zdarzenie rzeczywiście jest incydem, a nie fałszywym alarmem. Fałszywy alarm zamyka się z adnotacją o przyczynie; wpis pozostaje w Rejestrze.
- 6.6. Powiadomienie dyżurnych. Przy zdarzeniach, które mogą mieć poziom wysoki lub krytyczny, dyżurny niezwłocznie powiadamia kierownika Jednostki bezpieczeństwa i dyżurnego Jednostki informatyki.
- 6.7. Monitoring transakcji. Jednostka bezpieczeństwa prowadzi monitoring transakcji pod kątem nadużyć, korzystając z reguł wykrywania wzorców charakterystycznych dla oszustw płatniczych, takich jak:
 - 6.7.1. seria transakcji o nietypowych wartościach lub w krótkich odstępach czasu;
 - 6.7.2. logowanie z nowych urządzeń lub lokalizacji, połączone z szybką zmianą danych kontaktowych Klienta;
 - 6.7.3. nagłe podwyższenie limitów, po którym następują wypłaty lub przelewy na nowe rachunki;
 - 6.7.4. zbieżność wielu transakcji na ten sam rachunek odbiorcy, co może wskazywać na rachunek wykorzystywany do wyprowadzania środków.
- 6.8. Postępowanie po alarmie. Gdy reguła wykryje podejrzaną transakcję, analityk w pierwszej kolejności blokuje jej realizację, o ile pozwala na to system, a następnie kontaktuje się z Klientem kanałem zgodnym z danymi zapisanymi w Banku, aby potwierdzić autentyczność operacji.
- 6.9. Przekazanie do Jednostki zgodności. Jeżeli podejrzenie nadużycia wskazuje również na ryzyko prania pieniędzy, analityk przekazuje sprawę Jednostce zgodności, nie informując Klienta o możliwym zgłoszeniu transakcji do właściwych organów — zob. ustawa z dnia 1 marca 2018 r. o przeciwdziałaniu praniu pieniędzy oraz finansowaniu terroryzmu (Dz. U. 2025 poz. 644).
- 6.10. Zgłoszenia Klientów. Pracownik infolinii, placówki lub Jednostki obsługi klienta, który otrzyma od Klienta informację sugerującą incydent, postępuje następująco:
 - 6.10.1. wysłuchuje Klienta, nie żądając od niego pełnych danych uwierzytelniających, i zapisuje przebieg zdarzenia, w tym godzinę, kanał i sposób, w jaki Klient zorientował się o nieprawidłowości;

- 6.10.2. zaleca Klientowi zmianę hasła lub zablokowanie instrumentu płatniczego, jeżeli istnieje ryzyko dalszych nieautoryzowanych operacji;
- 6.10.3. zgłasza sprawę dyżurnemu Jednostki bezpieczeństwa w ciągu 30 minut, wskazując, czy podobne zgłoszenia już wpłynęły;
- 6.10.4. informuje Klienta, że sprawa zostanie wyjaśniona, a o jej wyniku Klient zostanie poinformowany w terminie wynikającym z przepisów o usługach płatniczych — zob. ustawa z dnia 19 sierpnia 2011 r. o usługach płatniczych (Dz. U. 2024 poz. 30).
- 6.11. Wzrost liczby zgłoszeń. Jeżeli w ciągu godziny wpłynie nietypowo duża liczba podobnych zgłoszeń Klientów, kierownik zmiany infolinii zgłasza to dyżurnemu Jednostki bezpieczeństwa jako możliwy incydent masowy, nawet przed ustaleniem jego przyczyny.
- 6.12. Dyżury i dostępność. Jednostka bezpieczeństwa i Jednostka informatyki zapewniają dyżury w trybie całodobowym. Harmonogram dyżurów jest dostępny w systemie zgłoszeń i przekazywany dyżurnym telefonicznie na początku każdego miesiąca.
- 6.13. Zasady dyżuru poza godzinami pracy. Dyżurny poza godzinami pracy:
 - 6.13.1. jest osiągalny pod numerem służbowym i podejmuje zgłoszenie w czasie pierwszej reakcji właściwym dla poziomu ważności;
 - 6.13.2. ma zdalny dostęp do Rejestru i systemu SIEM oraz aktualną listę kontaktów alarmowych;
 - 6.13.3. w przypadku niemożności objęcia dyżuru bez zbędnej zwłoki powiadamia kierownika Jednostki bezpieczeństwa, który wyznacza zastępstwo.
- 6.14. Lista kontaktów alarmowych. Lista kontaktów alarmowych obejmuje numery służbowe członków Zespołu, dyrektorów jednostek, kluczowych dostawców, zespołu CSIRT i organu nadzoru. Lista jest przechowywana również w postaci papierowej w zabezpieczonym miejscu, tak aby była dostępna w razie niedostępności systemów.
- 6.15. Podatności i zdarzenia wykryte w testach. Zdarzenia, w których test penetracyjny, skan podatności lub audyt wykażą możliwość nieuprawnionego dostępu do danych Klientów, ocenia Jednostka bezpieczeństwa pod kątem tego, czy podatność została już wykorzystana.
 - 6.15.1. Gdy istnieją ślady wykorzystania podatności, zdarzenie rejestruje się jako incydent i klasyfikuje według zasad ogólnych.
 - 6.15.2. Jeżeli brak takich śladów, podatność ujmuje się w rejestrze podatności i usuwa w terminie zależnym od jej krytyczności, a Rejestr zawiera odniesienie do decyzji o nierejestrowaniu incydentu.
- 6.16. Informacje z zewnątrz. Ostrzeżenia o nowych zagrożeniach otrzymane od zespołu CSIRT, producentów oprogramowania lub z publicznych źródeł Jednostka bezpieczeństwa porównuje z zasobami Banku i w przypadku potrzeby inicjuje działania zapobiegawcze, zanim dojdzie do incydentu.
- 6.17. Obsługa alertów z systemu SIEM. Analitycy Jednostki bezpieczeństwa przeglądają alerty z systemu SIEM w sposób ciągły, w kolejności wynikającej z priorytetu reguły, która alert wygenerowała.
 - 6.17.1. Alert o priorytecie wysokim analityk weryfikuje bezzwłocznie; jeżeli potwierdza

zdarzenie, rejestruje je jako incydent.

6.17.2. Alert fałszywie dodatni analityk oznacza w systemie wraz z krótkim uzasadnieniem, aby przy kolejnym przeglądzie reguł zmniejszyć liczbę podobnych alertów.

6.17.3. Alerty niepotwierdzone, ale powtarzające się w krótkim czasie, łączy się i analizuje łącznie.

6.18. Przegląd reguł. Jednostka bezpieczeństwa przegląda reguły korelacji zdarzeń przynajmniej raz na kwartał oraz po każdym incydencie, w którym zdarzenie nie zostało wykryte przez system lub zostało wykryte z opóźnieniem.

7. Opis postępowania — klasyfikacja i ocena incydentu

Klasyfikacja incydentu służy ustaleniu wymaganego czasu reakcji, składu zespołu obsługującego incydent i zakresu zawiadomień. Poziom ważności określa się na podstawie najpoważniejszego ze skutków wskazanych w tabeli. Pełną macierz klasyfikacji zawiera Załącznik nr 1.

Poziom ważności	Kryteria (wystarczy spełnienie jednego)	Pierwsza reakcja — do
Krytyczny	incydent dotyczy ponad 1 000 Klientów, albo niedostępność kluczowej usługi trwa dłużej niż 2 godziny, albo potencjalna strata przekracza 500 000,00 zł, albo doszło do naruszenia danych o wysokim ryzyku	15 minut
Wysoki	incydent dotyczy od 100 do 1 000 Klientów, albo niedostępność usługi trwa od 30 minut do 2 godzin, albo potencjalna strata przekracza 50 000,00 zł	1 godziny
Średni	ograniczone zakłócenie jednego procesu lub kanału, bez wpływu na rozliczenia, z istniejącym obejściem	4 godzin
Niski	zdarzenie bez wpływu na Klientów i procesy, zablokowane w całości przez zabezpieczenia	2 dni roboczych

7.1. Ocena wstępna. Dyżurny Jednostki bezpieczeństwa dokonuje wstępnej klasyfikacji w ciągu 2 godzin od zarejestrowania zgłoszenia.

7.1.1. Klasyfikacja obejmuje ocenę wpływu na poufność, integralność i dostępność informacji, liczbę dotkniętych Klientów, wartość operacji i ryzyko dla reputacji Banku.

7.1.2. Gdy dane są niepełne, przyjmuje się poziom wyższy; obniżenie poziomu jest możliwe dopiero po uzyskaniu pełnych danych.

7.2. Ustalenie rodzaju incydentu. Dyżurny przypisuje incydent do kategorii: złośliwe oprogramowanie, nieuprawniony dostęp, odmowa usługi, wyludzenie danych, wyciek danych, awaria systemu, błąd przetwarzania, incydent dostawcy lub incydent fizyczny. Kategoria wpływa na doborze członków Zespołu.

7.3. Ocena obowiązków zewnętrznych. Jednostka zgodności oraz Inspektor oceniają, czy incydent:

7.3.1. spełnia kryteria incydentu poważnego i wymaga zawiadomienia organu nadzoru;

- 7.3.2. stanowi naruszenie ochrony danych osobowych wymagające zgłoszenia do organu ochrony danych lub powiadomienia osób, których dane dotyczą;
- 7.3.3. wymaga zawiadomienia organów ścigania lub innych uprawnionych instytucji.
- 7.4. Powołanie Zespołu. Incydent o poziomie wysokim lub krytycznym obsługuje Zespół, którego kierownikiem jest wyznaczony przedstawiciel Jednostki bezpieczeństwa. Dla incydentów średnich i niskich obsługę prowadzi dyżurny wraz z właściwą jednostką.
- 7.5. Zmiana poziomu ważności. Poziom ważności może zostać zmieniony w trakcie obsługi, jeżeli pojawią się nowe informacje. Zmianę wraz z uzasadnieniem i godziną odnotowuje się w Rejestrze; podwyższenie poziomu uruchamia obowiązki właściwe dla nowego poziomu od chwili zmiany.
- 7.6. Eskalacja. Incydent krytyczny kierownik Jednostki bezpieczeństwa niezwłocznie zgłasza członkowi Zarządu nadzorującemu ryzyko; incydent wysoki — dyrektorom departamentów dotkniętych incydem.
- 7.7. Kategorie szczegółowe. Przy rejestracji incydemu wskazuje się kategorię główną i, gdy to możliwe, podkategorię. Przyjęto następujące kategorie główne:
 - 7.7.1. złośliwe oprogramowanie — wirusy, trojany, oprogramowanie szyfrujące i szpiegujące;
 - 7.7.2. nieuprawniony dostęp — przejęcie konta, obejście uwierzytelniania, nadużycie uprawnień;
 - 7.7.3. odmowa usługi — celowe przeciążenie systemów lub sieci;
 - 7.7.4. wyłudzenie danych — wiadomości lub rozmowy, w których sprawca podszywa się pod Bank lub Klienta;
 - 7.7.5. wyciek danych — ujawnienie danych osobom nieuprawnionym;
 - 7.7.6. awaria — niezamierzona niedostępność lub nieprawidłowe działanie systemu;
 - 7.7.7. błąd przetwarzania — nieprawidłowe zaksięgowanie, naliczenie lub przekazanie operacji;
 - 7.7.8. incydent dostawcy — incydent po stronie podmiotu zewnętrznego wpływający na usługi Banku;
 - 7.7.9. incydent fizyczny — kradzież, włamanie, pożar, zalanie lub inne zdarzenie w lokalu.
- 7.8. Zmiana kategorii. Kategorię można zmienić po uzyskaniu nowych informacji; zmianę odnotowuje się w Rejestrze, a pierwotną kategorię zachowuje się w historii wpisu.
- 7.9. Ocena ryzyka naruszenia danych. Inspektor ocenia ryzyko dla osób, których dane dotyczą, uwzględniając:
 - 7.9.1. rodzaj i wrażliwość danych (dane identyfikacyjne, finansowe, dane szczególnych kategorii);
 - 7.9.2. liczbę osób i łatwość ich identyfikacji na podstawie ujawnionych danych;
 - 7.9.3. zakres zabezpieczeń zastosowanych do danych, zwłaszcza szyfrowanie, które mogłoby uniemożliwić zapoznanie się z nimi;
 - 7.9.4. prawdopodobne skutki dla osób, takie jak kradzież tożsamości, strata finansowa, dyskryminacja lub naruszenie dobrego imienia.
- 7.10. Dokumentowanie oceny. Wynik oceny, wraz z uzasadnieniem, Inspektor wpisuje do

- Rejestru, także wtedy, gdy uznaje, że zgłoszenie do organu ochrony danych nie jest wymagane.
- 7.11. Incydenty powiązane. Gdy kilka zgłoszeń ma tę samą przyczynę, rejestruje się jeden incydent nadrzędny, a pozostałe zgłoszenia łączy się z nim jako zdarzenia podrzędne. Poziom ważności ustala się dla całości.
- 7.12. Incydenty jednoczesne. Jeżeli w tym samym czasie występuje kilka niepowiązanych incydentów, kierownik Jednostki bezpieczeństwa ustala kolejność ich obsługi i wyznacza odrębnych kierowników incydentów; Zespół może być w takim przypadku podzielony na grupy.
- 7.13. Incydent nawracający. Incydent, który powtarza się z tą samą przyczyną w ciągu ostatnich sześciu miesięcy, klasyfikuje się co najmniej o jeden poziom wyżej niż poprzednie wystąpienie, a przegląd po incydencie jest obowiązkowy niezależnie od poziomu.
- 7.14. Szacowanie skutków finansowych. Przy klasyfikacji określa się potencjalną stratę finansową, obejmującą:
- 7.14.1. bezpośrednie straty Klientów i Banku wynikające z nieautoryzowanych lub błędnych operacji;
 - 7.14.2. koszty usunięcia skutków incydentu, w tym pracę zespołów i usługi zewnętrzne;
 - 7.14.3. przewidywane odszkodowania, kary lub rekompensaty dla Klientów;
 - 7.14.4. utracone przychody z tytułu niedostępności usług.
- 7.15. Szacunek wstępny. Szacunek wstępny jest oceną ostrożnościową — przyjmuje się wartość górnej granicy rozsądnego przedziału. Jednostka ryzyka weryfikuje szacunek po zamknięciu incydentu i przekazuje wartość rzeczywistą do Rejestru.
- 7.16. Skutki niefinansowe. Obok skutków finansowych ocenia się wpływ na zaufanie Klientów, relacje z organem nadzoru, możliwość wykonywania zobowiązań wobec partnerów rozliczeniowych oraz bezpieczeństwo pracowników.
- 7.17. Incydenty po stronie dostawców. Incydent po stronie dostawcy rejestruje się i klasyfikuje według tych samych kryteriów co incydent własny, uwzględniając wpływ na usługi dla Klientów, a nie wagę, jaką nadał mu dostawca.
- 7.17.1. Jednostka bezpieczeństwa prosi dostawcę o informacje pozwalające ocenić zakres incydentu, zwłaszcza o dane dotyczące wpływu na dane Banku.
 - 7.17.2. Jeżeli dostawca nie przekazuje informacji w uzgodnionym terminie, przyjmuje się założenie najgorszego wiarygodnego scenariusza.
 - 7.17.3. Właściciel umowy z dostawcą rejestruje przypadki niedotrzymania obowiązków informacyjnych i uwzględnia je w ocenie dostawcy.

8. Opis postępowania — reagowanie i ograniczanie skutków

- 8.1. Uruchomienie Zespołu. Kierownik incydentu zwołuje Zespół w czasie pierwszej reakcji właściwym dla poziomu ważności i otwiera pokój operacyjny, w którym prowadzi się chronologiczny zapis ustaleń i decyzji.
- 8.1.1. Każdy członek Zespołu potwierdza gotowość i podaje zakres swoich działań.
 - 8.1.2. Kierownik incydentu przydziela zadania i wyznacza osobę prowadzącą dziennik

zdarzeń.

- 8.2. Ocena zakresu. Jednostka informatyki ustala, które systemy, dane i konta są dotknięte incydem, od kiedy i w jaki sposób do niego doszło, oraz czy incydent trwa.
- 8.3. Ograniczenie skutków. Zespół podejmuje działania zatrzymujące rozprzestrzenianie się incydem, dobierając je do rodzaju zdarzenia:
 - 8.3.1. odłączenie zainfekowanych stacji i segmentów od sieci Banku bez wyłączenia zasilania (aby zachować zawartość pamięci);
 - 8.3.2. zablokowanie lub zmiana danych uwierzytelniających przejętych kont, tokenów i certyfikatów;
 - 8.3.3. zablokowanie złośliwych adresów, domen i nadawców wiadomości na urządzeniach brzegowych;
 - 8.3.4. czasowe wyłączenie podatnej funkcji lub kanału, jeżeli jest to proporcjonalne do ryzyka;
 - 8.3.5. wstrzymanie wypłat lub zleceń płatniczych objętych podejrzeniem nadużycia, w uzgodnieniu z Jednostką operacji.
- 8.4. Decyzje o wyłączeniu usług. Decyzję o wyłączeniu kanału lub usługi dla Klientów podejmuje kierownik incydem w porozumieniu z dyrektorem Jednostki operacji; w przypadku incydem krytycznego powiadamia się o niej członek Zarządu. Wyłączenie ma trwać jak najkrócej, a jego przyczyny, czas i zakres odnotowuje się w dzienniku zdarzeń.
- 8.5. Zabezpieczenie dowodów przed naprawą. Zanim wykona się czynności zmieniające stan systemów (restart, reinstalacja, czyszczenie), zabezpiecza się materiał dowodowy zgodnie z zasadami opisanymi w dalszej części procedury.
- 8.6. Usunięcie przyczyny. Po ograniczeniu skutków Zespół usuwa przyczynę incydem:
 - 8.6.1. usuwa złośliwe oprogramowanie i wszelkie mechanizmy trwałej obecności atakującego;
 - 8.6.2. instaluje poprawki i zmienia konfigurację, które umożliwiły incydent;
 - 8.6.3. sprawdza, czy w innych systemach nie występują te same słabości;
 - 8.6.4. dokumentuje wykonane czynności w karcie incydem.
- 8.7. Raport stanu. Kierownik incydem przygotowuje cykliczny raport stanu: dla incydem krytycznego co godzinę, dla wysokiego — co cztery godziny. Raport obejmuje status, podjęte działania, planowane czynności i szacowany czas przywrócenia usług.
- 8.8. Współpraca z wyspecjalizowanymi podmiotami. Gdy Bank nie dysponuje wystarczającymi zasobami do analizy lub usunięcia skutków incydem, kierownik incydem może za zgodą dyrektora Jednostki bezpieczeństwa skorzystać ze wsparcia zewnętrznego zespołu specjalistów, z którym Bank ma zawartą umowę ramową.
 - 8.8.1. Umowa z zewnętrznym zespołem obejmuje klauzule poufności i zapewnia, że zespół działa pod nadzorem Banku.
 - 8.8.2. Dostęp zespołu do systemów i danych ogranicza się do niezbędnego zakresu i rejestruje.
 - 8.8.3. Wyniki analizy zespół przekazuje jedynie Bankowi.
- 8.9. Zmiany w systemach w trakcie incydem. Zmiany w systemach dokonywane w trakcie

- obsługi incydu (poprawki, zmiany konfiguracji, wyłączenia) wymagają zgody kierownika incydu i są odnotowywane w dzienniku zdarzeń. Procedura zarządzania zmianą w trybie przyspieszonym obejmuje następujące uproszczenia:
- 8.9.1. zgodę na zmianę wydaje kierownik incydu zamiast zwykłego komitetu zmian;
 - 8.9.2. dokumentację zmiany uzupełnia się nie później niż w terminie 7 dni po zamknięciu incydu;
 - 8.9.3. zmiany niekonieczne do ograniczenia skutków odkłada się do czasu zakończenia incydu.
- 8.10. Tryb awaryjny. Jeżeli przywrócenie usługi w czasie wynikającym z RTO nie jest możliwe, kierownik incydu wraz z Jednostką ciągłości wnioskuje do członka Zarządu o uruchomienie planu ciągłości działania.
- 8.10.1. Plan ciągłości działania uruchamia się decyzją członka Zarządu nadzorującego operacje lub osoby przez niego upoważnionej; decyzję odnotowuje się w dzienniku zdarzeń.
 - 8.10.2. W trybie awaryjnym placówki obsługują Klientów według uproszczonych zasad i w ograniczonym zakresie czynności, zgodnie z planem.
 - 8.10.3. Operacje wykonane w trybie awaryjnym oznacza się i po przywróceniu systemów rekonsyliuje z danymi systemu centralnego CBS-PRZYKŁAD.
- 8.11. Izolacja systemów i sieci. Izolację zainfekowanych lub przejętych systemów przeprowadza Jednostka informatyki na polecenie kierownika incydu. Przed izolacją ocenia się, czy odłączenie nie spowoduje większej szkody niż pozostawienie systemu w sieci.
- 8.11.1. Dla systemów krytycznych decyzję o izolacji podejmuje kierownik incydu w porozumieniu z właścicielem systemu.
 - 8.11.2. Systemy odłączone oznacza się w Rejestrze i w dzienniku zdarzeń, ze wskazaniem godziny odłączenia i osoby, która tego dokonała.
 - 8.11.3. Aby ponownie podłączyć system, wymagana jest zgoda kierownika incydu.
- 8.12. Segmentacja. Zespół stosuje istniejący podział sieci na segmenty, aby ograniczyć rozprzestrzenianie się incydu; w razie potrzeby czasowo zamyka połączenia między segmentami.
- 8.13. Zarządzanie danymi uwierzytelniającymi. Gdy istnieje podejrzenie przejęcia kont, Jednostka informatyki:
- 8.13.1. zmienia hasła i unieważnia sesje oraz tokeny kont, których dotyczy podejrzenie;
 - 8.13.2. w pierwszej kolejności zabezpiecza konta uprzywilejowane i konta usługowe;
 - 8.13.3. zmienia klucze i certyfikaty, gdy mogły zostać ujawnione;
 - 8.13.4. sprawdza ostatnie logowania pod kątem wcześniejszej, niezauważonej aktywności atakującego.
- 8.14. Zablokowanie kart i rachunków Klientów. Gdy incydent może prowadzić do nieautoryzowanych transakcji na kartach lub rachunkach Klientów, Jednostka operacji — na polecenie kierownika incydu — czasowo blokuje dotknięte instrumenty płatnicze i rachunki oraz uruchamia proces wydania nowych instrumentów bez opłat dla Klienta.

9. Opis postępowania — komunikacja i raportowanie

Komunikację w trakcie incydentu prowadzi się jedynie według zasad poniżej. Pracownicy nieupoważnieni do kontaktu z mediami, Klientami lub instytucjami zewnętrznymi nie udzielają informacji o incydencie i kierują wszelkie pytania do Jednostki komunikacji.

- 9.1. Komunikacja wewnętrzna. Kierownik incydentu informuje o incydencie osoby i jednostki, które muszą podjąć działania, w zakresie koniecznym do ich wykonania.
 - 9.1.1. Informacje o incydentach krytycznych i wysokich przekazuje się w pokoju operacyjnym, a gdy ten jest niedostępny — telefonicznie.
 - 9.1.2. Pracownikom placówek i infolinii przekazuje się krótką instrukcję: co wiadomo, co mówić Klientom i dokąd kierować pytania.
 - 9.1.3. Informacje o przyczynach i sprawcach incydentu nie są przekazywane pracownikom spoza Zespołu do czasu zakończenia analizy.
- 9.2. Komunikacja z Klientami. Jeżeli incydent dotyczy Klientów, Jednostka komunikacji przygotowuje komunikat, który:
 - 9.2.1. w prosty sposób informuje, czego incydent dotyczy i jakich usług lub produktów;
 - 9.2.2. wskazuje zalecane działania Klienta (np. zmiana hasła, unikanie wskazanych linków) oraz numer infolinii 800 000 001;
 - 9.2.3. nie zawiera szczegółów technicznych, które mogłyby ułatwić dalsze ataki;
 - 9.2.4. przypomina, że Bank nie prosi o podanie pełnych danych uwierzytelniających.
- 9.3. Termin powiadomienia Klientów. Klientów, których dotyczy incydent o wysokim ryzyku dla ich środków lub danych, powiadamia się w terminie 24 godzin od potwierdzenia, że incydent ich dotyczy. Gdy tożsamość dotkniętych Klientów nie jest jeszcze znana, zamieszcza się komunikat ogólny w bankowości elektronicznej i na stronie <https://bank.example>.

Incydenty poważne oraz naruszenia ochrony danych osobowych podlegają zgłoszeniu w terminach określonych poniżej. Terminy liczy się w godzinach, a nie w dniach roboczych — obejmują one dni ustawowo wolne od pracy, noce i weekendy.

- 9.4. Kwalifikacja incydentu poważnego. Jednostka zgodności wspólnie z Jednostką bezpieczeństwa ustala, czy incydent jest incydemtem poważnym. Przy ocenie uwzględnia się zwłaszcza liczbę dotkniętych Klientów, czas trwania, zasięg, wartość transakcji, wpływ na inne instytucje i skutki dla reputacji Banku. Decyzję odnotowuje się w Rejestrze.
- 9.5. Zawiadomienie wstępne. Zawiadomienie wstępne dla organu nadzoru przekazuje się w ciągu 6 godzin od zaklasyfikowania incydentu jako poważnego, a w każdym razie nie później niż w terminie 24 godzin od momentu, w którym Bank dowiedział się o incydencie.
 - 9.5.1. Zawiadomienie przygotowuje Jednostka bezpieczeństwa na formularzu F-BEZ-06, a opiniuje Jednostka zgodności.
 - 9.5.2. Zawiadomienie zawiera dane Banku, datę i godzinę wykrycia, wstępny opis incydentu, szacowany zasięg i rodzaj dotkniętych usług, informację o podjętych działaniach i dane osoby kontaktowej.

- 9.5.3. Zawiadomienie przekazuje się bezpiecznym kanałem wskazanym przez organ nadzoru; brak pełnych danych nie jest powodem opóźnienia — uzupełnia się je w zawiadomieniach kolejnych.
- 9.6. Zawiadomienie pośrednie. Zawiadomienie pośrednie przekazuje się w terminie 72 godzin od zawiadomienia wstępnego albo niezwłocznie po istotnej zmianie stanu incydentu, jeżeli nastąpi ona wcześniej.
 - 9.6.1. Zawiadomienie pośrednie zawiera zaktualizowany opis incydentu, ustaloną przyczynę (jeśli jest znana), liczbę dotkniętych Klientów, wartość operacji, podjęte działania naprawcze i przewidywany czas przywrócenia usług.
 - 9.6.2. Kolejne aktualizacje przekazuje się w miarę potrzeb, aż do zakończenia incydentu.
- 9.7. Raport końcowy. Raport końcowy przekazuje się w terminie 1 miesiąca od zawiadomienia pośredniego albo od ustania incydentu, zależnie od tego, które zdarzenie nastąpi później. Raport według formularza F-BEZ-03 obejmuje analizę przyczyny źródłowej, pełne skutki, wykonane i planowane środki zaradcze oraz informacje o ewentualnych kosztach.
- 9.8. Naruszenie ochrony danych osobowych — zgłoszenie. Jeżeli Inspektor stwierdzi, że naruszenie może skutkować ryzykiem naruszenia praw lub wolności osób fizycznych, Bank zgłasza je organowi ochrony danych bez zbędnej zwłoki, w miarę możliwości nie później niż w terminie 72 godzin od stwierdzenia naruszenia. Zgłoszenie dokonane po tym terminie wymaga wyjaśnienia przyczyn opóźnienia.
 - 9.8.1. Zgłoszenie obejmuje charakter naruszenia, kategorie i przybliżoną liczbę osób oraz rekordów, dane kontaktowe Inspektora (iod@bank.example), możliwe skutki oraz środki zastosowane lub proponowane.
 - 9.8.2. Podstawę prawną zgłoszenia stanowią przepisy o ochronie danych osobowych — zob. ustawa z dnia 10 maja 2018 r. o ochronie danych osobowych (Dz. U. 2019 poz. 1781).
- 9.9. Naruszenie ochrony danych osobowych — powiadomienie osób. Jeżeli naruszenie może powodować wysokie ryzyko naruszenia praw lub wolności osób, których dane dotyczą, Inspektor wspólnie z Jednostką komunikacji przygotowuje powiadomienie tych osób, napisane prostym językiem, i przekazuje je bez zbędnej zwłoki.
- 9.10. Instrukcja dla infolinii i placówek. Jednostka obsługi klienta otrzymuje od kierownika incydentu krótką instrukcję, która zawiera:
 - 9.10.1. stan faktyczny w zakresie, w jakim można go przekazać Klientom;
 - 9.10.2. zalecenia, których należy udzielić Klientom (np. czasowe zaprzestanie korzystania z danej usługi, zmiana hasła);
 - 9.10.3. informację, jak postępować z Klientami, którzy zgłaszają straty;
 - 9.10.4. dane osoby w Jednostce obsługi klienta, do której kieruje się trudniejsze pytania.
- 9.11. Skrypt rozmowy. Pracownicy infolinii korzystają z zatwierdzonego skryptu rozmowy i nie przekraczają zawarte w nim informacje. Pytania, na które skrypt nie daje odpowiedzi, rejestruje się i przekazuje kierownikowi incydentu.
- 9.12. Informowanie kierownictwa. Kierownictwo Banku jest powiadamiane w zakresie zależnym od poziomu ważności:
 - 9.12.1. poziom krytyczny — niezwłoczna informacja telefoniczna dla członka Zarządu

- nadzorującego ryzyko, a następnie raporty stanu w ustalonych odstępach;
- 9.12.2. poziom wysoki — informacja dla dyrektorów departamentów dotkniętych incydem oraz zbiorcza informacja w kwartalnym sprawozdaniu;
- 9.12.3. poziom średni i niski — informacja w miesięcznym zestawieniu Jednostki bezpieczeństwa.
- 9.13. Zawartość informacji. Informacja dla kierownictwa jest krótka i zawiera: co się stało, jakie są skutki, co zrobiono, co planuje się zrobić i jakich decyzji wymaga się od kierownictwa.
- 9.14. Komunikacja z mediami. Z mediami kontaktuje się wyłącznie Jednostka komunikacji za zgodą Zarządu. Treść oświadczeń zatwierdza Jednostka prawna w zakresie ryzyka prawnego, a kierownik incydentu — w zakresie zgodności z faktami.
- 9.14.1. Oświadczenie publiczne obejmuje tylko potwierdzone informacje i nie przesądza o przyczynach ani sprawcach incydentu.
- 9.14.2. Pracownicy, którzy otrzymają pytanie dziennikarza, nie udzielają odpowiedzi i przekazują kontakt do Jednostki komunikacji.
- 9.14.3. Wypowiedzi w mediach społecznościowych o incydencie w imieniu Banku wygłasza wyłącznie Jednostka komunikacji.
- 9.15. Monitorowanie reakcji. Jednostka komunikacji monitoruje publikacje i wpisy dotyczące incydentu i przekazuje kierownikowi incydentu informacje o nieprawdziwych lub szkodliwych doniesieniach.
- 9.16. Zawiadomienie o przestępstwie. W razie uzasadnionego podejrzenia popełnienia przestępstwa Jednostka prawna w porozumieniu z Jednostką bezpieczeństwa składa zawiadomienie do właściwych organów ścigania i uzgadnia z nimi zakres współpracy.
- 9.16.1. Rozmiar informacji przekazywanych organom ścigania musi być zgodny z przepisami o tajemnicy bankowej — zob. ustawa z dnia 29 sierpnia 1997 r. – Prawo bankowe (Dz. U. 2024 poz. 1646).
- 9.16.2. Przekazanie materiału dowodowego organom ścigania dokumentuje się protokołem według formularza F-BEZ-04.
- 9.16.3. Pracownik Banku nie informuje osób podejrzewanych o toczących się czynnościach.
- 9.17. Współpraca z zespołem CSIRT. W incydentach o charakterze cyberataku Jednostka bezpieczeństwa może przekazać zespołowi CSIRT informacje o wskaźnikach naruszenia bezpieczeństwa (adresy, skróty plików, domeny) w formie pozbawionej danych Klientów. Przekazywanie takich informacji ułatwia ochronę innych instytucji, a Bank może uzyskać od zespołu wsparcie analityczne.
- 9.18. Inne instytucje. Jeżeli incydent może wpływać na partnerów rozliczeniowych, operatorów systemów płatności lub inne instytucje finansowe, kierownik incydentu w porozumieniu z Jednostką zgodności informuje je w zakresie niezbędnym do ochrony ich systemów.

10. Opis postępowania — zabezpieczenie dowodów, przywrócenie działania i przegląd

- 10.1. Zasady zabezpieczania materiału dowodowego. Materiał dowodowy zabezpiecza się w sposób, który umożliwia wykazać jego autentyczność i nienaruszalność. Czynności wykonują wyłącznie osoby wyznaczone przez kierownika incydentu.
 - 10.1.1. Przed każdą czynnością zmieniającą stan systemu wykonuje się kopię logów, obraz dysku lub zrzut pamięci, a dla każdej kopii oblicza się sumę kontrolną.
 - 10.1.2. Oryginały dowodów przechowuje się w oznaczonym, zabezpieczonym miejscu; analizę prowadzi się na kopiach.
 - 10.1.3. Każde przekazanie dowodu odnotowuje się w protokole według formularza F-BEZ-04 (łańcuch dowodowy): data, godzina, osoba przekazująca, osoba przyjmująca, cel.
- 10.2. Rodzaje zabezpieczanych danych. Zabezpiecza się zwłaszcza:
 - 10.2.1. logi systemowe, aplikacyjne, sieciowe i uwierzytelniania z okresu przynajmniej 13 miesięcy wstecz — o ile taki okres jest dostępny;
 - 10.2.2. obrazy dysków i zrzuty pamięci zainfekowanych stacji i serwerów;
 - 10.2.3. wiadomości phishingowe wraz z nagłówkami technicznymi;
 - 10.2.4. zapisy rozmów telefonicznych i korespondencję z osobami zgłaszającymi;
 - 10.2.5. zapisy z monitoringu wizyjnego i rejestry wejść w przypadku incydentów fizycznych.
- 10.3. Wstrzymanie usuwania danych. Na czas obsługi incydentu i do zamknięcia wszystkich związanych z nim postępowań Jednostka informatyki wstrzymuje automatyczne usuwanie logów i kopii objętych incydemem (blokada prawna na wniosek Jednostki prawnej).
- 10.4. Ochrona danych w materiale dowodowym. Materiał dowodowy obejmuje często dane osobowe i tajemnicę bankową. Dostęp do niego mają wyłącznie osoby, które go potrzebują do obsługi incydentu; dostęp rejestruje się, a przekazanie materiału poza Bank wymaga zgody Jednostki prawnej.
- 10.5. Plan przywrócenia. Kierownik incydentu wraz z Jednostką informatyki i Jednostką ciągłości ustala kolejność przywracania usług, opierając się na priorytetach określonych w planie ciągłości działania i wartościach RTO oraz RPO. Priorytet mają usługi umożliwiające Klientom dostęp do środków i realizację płatności.
- 10.6. Przywrócenie z kopii. Przywracanie systemów z kopii zapasowych poprzedza sprawdzenie, że kopie nie zostały zainfekowane. Systemy, które były przejęte, przywraca się z zaufanych, zweryfikowanych źródeł, nigdy przez proste usunięcie śladów.
 - 10.6.1. Przed uruchomieniem systemu wykonuje się skanowanie antywirusowe i weryfikację integralności konfiguracji.
 - 10.6.2. Wszystkie hasła, klucze i certyfikaty związane z przywracanym systemem są zmieniane.
 - 10.6.3. System włącza się najpierw w trybie ograniczonym, z podwyższonym monitoringiem.

- 10.7. Weryfikacja poprawności danych. Jednostka operacji porównuje stan rachunków i rozliczeń z danymi sprzed incydentu, ustala operacje wykonane w trakcie awarii oraz koryguje wszelkie nieprawidłowe księgowania. Korekty dokonuje się przez zapisy odwracające, z odniesieniem do numeru incydentu.
- 10.8. Skutki finansowe dla Klientów. Jeżeli w wyniku incydentu doszło do nieautoryzowanych transakcji na rachunkach Klientów, Bank zwraca kwotę nieautoryzowanej transakcji do końca następnego dnia roboczego po stwierdzeniu lub zgłoszeniu takiej transakcji, chyba że istnieją uzasadnione i udokumentowane podstawy podejrzenia oszustwa po stronie Klienta — o czym zawiadamia się właściwy organ. Zasady te wynikają z przepisów o usługach płatniczych — zob. ustawa z dnia 19 sierpnia 2011 r. o usługach płatniczych (Dz. U. 2024 poz. 30).
- 10.9. Zakończenie przywracania. Kierownik incydentu zamyka fazę przywracania po łącznym spełnieniu warunków:
 - 10.9.1. usługi działają stabilnie w uzgodnionym oknie obserwacji;
 - 10.9.2. przyczyna incydentu została usunięta lub skutecznie zneutralizowana;
 - 10.9.3. dotknięci Klienci zostali poinformowani, a ich środki zabezpieczone;
 - 10.9.4. wszystkie wymagane zawiadomienia zostały przekazane.
- 10.10. Zamknięcie incydentu. Incydent zamyka dyżurny Jednostki bezpieczeństwa po akceptacji kierownika incydentu, uzupełniając Rejestr o datę i godzinę zakończenia, ostateczny poziom ważności, przyczynę źródłową i wartość strat.
- 10.11. Przegląd po incydencie. Dla każdego incydentu o poziomie wysokim lub krytycznym oraz dla każdego incydentu, który spowodował wyjątkowe skutki, Jednostka bezpieczeństwa wykonuje przegląd w terminie 14 dni od zamknięcia incydentu.
 - 10.11.1. W przeglądzie biorą udział kierownik incydentu, członkowie Zespołu i przedstawiciele jednostek, których incydent dotyczył; spotkanie prowadzi osoba niezwiązana bezpośrednio z obsługą incydentu.
 - 10.11.2. Przegląd ma charakter wyjaśniający, a nie wskazujący winnych; jego celem jest ustalenie, co zadziało, a co nie.
- 10.12. Zakres przeglądu. W przeglądzie bada się:
 - 10.12.1. przyczynę źródłową i czynniki, które umożliwiły incydent;
 - 10.12.2. skuteczność wykrycia, czyli czas od początku incydentu do jego wykrycia;
 - 10.12.3. skuteczność reakcji: czasy klasyfikacji, ograniczenia skutków i przywrócenia usług w porównaniu z wymaganiami;
 - 10.12.4. jakość komunikacji z Klientami, kierownictwem i podmiotami zewnętrznymi oraz dotrzymanie terminów zawiadomień;
 - 10.12.5. kompletność dokumentacji i materiału dowodowego.
- 10.13. Raport z przeglądu. Wyniki przeglądu opisuje się w raporcie według formularza F-BEZ-05, który w ciągu 7 dni od przeglądu zatwierdza dyrektor Jednostki bezpieczeństwa. Raport o incydencie krytycznym przekazuje się Zarządowi.
- 10.14. Wnioski i zalecenia. Z przeglądu wynikają zalecenia z przypisanymi właścicielami i terminami. Zalecenia wprowadza się do wspólnego planu działań, a ich realizację monitoruje Jednostka zgodności; termin realizacji zaleceń nie powinien przekraczać

- 90 dni od zatwierdzenia raportu, chyba że Jednostka bezpieczeństwa zatwierdzi inny, uzasadniony termin.
- 10.15. Wykorzystanie wniosków. Wnioski z przeglądu wykorzystuje się do aktualizacji reguł systemu SIEM, scenariuszy ćwiczeń, szkoleń pracowników, planów ciągłości działania, ocen dostawców oraz niniejszej procedury.
- 10.16. Etapowe wznawianie usług. Usługi wznawia się etapami, rozpoczynając od najważniejszych dla Klientów, a każdy etap kończy się weryfikacją poprawności działania. Kolejność etapów wynika z planu ciągłości działania, a odstępstwa wymagają zgody kierownika incydentu.
- 10.16.1. Etap 1 — usługi niezbędne do dostępu Klientów do środków: rachunki, wypłaty, płatności kartami.
- 10.16.2. Etap 2 — usługi płatnicze realizowane w bankowości elektronicznej oraz rozliczenia.
- 10.16.3. Etap 3 — pozostałe usługi, w tym wnioski, usługi doradcze i raportowe.
- 10.17. Komunikat o wznowieniu. Po wznowieniu każdego etapu Jednostka komunikacji informuje Klientów o przywróceniu usługi i, o ile to konieczne, o czynnościach, jakie powinni wykonać.
- 10.18. Roszczenia i ubezpieczenie. Gdy incydent spowodował szkodę, która może być przedmiotem roszczenia wobec dostawcy, sprawcy lub ubezpieczyciela, Jednostka prawna:
- 10.18.1. ustala dopuszczalne terminy zgłoszenia szkody i niezwłocznie je zachowuje;
- 10.18.2. zbiera dokumentację niezbędną do dochodzenia roszczeń, korzystając z materiału dowodowego zabezpieczonego w trakcie incydentu;
- 10.18.3. prowadzi korespondencję z ubezpieczycielem i dostawcą, uzgadniając jej treść z kierownikiem incydentu.
- 10.19. Ocena kar i sankcji. Jednostka zgodności sprawdza, czy incydent może skutkować nałożeniem sankcji przez organ nadzoru lub organ ochrony danych, i informuje o tym Zarząd wraz z propozycją działań ograniczających takie ryzyko.
- 10.20. Podwyższony monitoring. Po wznowieniu działania usług Jednostka bezpieczeństwa utrzymuje podwyższony monitoring odtworzonych systemów przez okres uzgodniony z kierownikiem incydentu, nie krócej niż siedem dni dla incydentów o poziomie wysokim i krytycznym.
- 10.20.1. Monitoring obejmuje poszukiwanie śladów ponownego włamania, nietypowych połączeń i prób logowania na przywróconych kontach.
- 10.20.2. Każdą anomalię zgłasza się niezwłocznie kierownikowi incydentu, który może ponownie otworzyć incydent.
- 10.21. Ponowne otwarcie incydentu. Zamknięty incydent można ponownie otworzyć, gdy w ciągu 14 dni od zamknięcia ujawnią się nowe okoliczności wskazujące na jego dalsze trwanie albo na nieskuteczne usunięcie przyczyny.
- 10.22. Rekuncylacja po incydencie. Po przywróceniu systemów Jednostka operacji wykonuje rekuncylację operacji dokonanych w okresie incydentu.
- 10.22.1. porównuje salda rachunków Klientów z zapisami w systemie centralnym i w systemach rozliczeniowych;

- 10.22.2. identyfikuje operacje zdublowane, utracone lub zaksięgowane z błędną datą;
 - 10.22.3. przygotowuje listę korekt wraz z uzasadnieniem i przekazuje ją do akceptacji kierownika incydu;
 - 10.22.4. po wykonaniu korekt sporządza protokół z rekuncyliacji, który dołącza się do dokumentacji incydu.
- 10.23. Odsetki i opłaty. Gd w wyniku błędu Klientowi naliczono opłaty lub odsetki, które nie byłyby naliczone w braku incydu, Bank je koryguje z urzędu, bez konieczności składania wniosku przez Klienta.

11. Testy i ćwiczenia

Skuteczność procedury sprawdza się w praktyce poprzez regularne testy i ćwiczenia. Ich harmonogram na dany rok zatwierdza dyrektor Jednostki bezpieczeństwa do końca stycznia.

- 11.1. Testy planów reagowania. Plany reagowania na incydenty i plany odtwarzania systemów testuje się raz w roku. Test obejmuje co najmniej scenariusze: awarii systemu centralnego, ataku szyfrującego dane i niedostępności kluczowego dostawcy.
- 11.2. Ćwiczenia stołowe. Zespół uczestniczy w ćwiczeniach stołowych dwa razy w roku. W ćwiczeniu omawia się wymyślony scenariusz incydu, role członków Zespołu, decyzje i komunikaty; z ćwiczenia sporządza się krótką notatkę z wnioskami.
- 11.3. Ćwiczenia praktyczne. Przynajmniej raz w roku wykonuje się ćwiczenie praktyczne z użyciem środowiska testowego lub kontrolowanej symulacji ataku, w którym sprawdza się działanie narzędzi wykrywania, kanałów powiadamiania i czasy reakcji.
- 11.4. Ocena wyników. Wyniki testów i ćwiczeń ocenia się według kryteriów: dotrzymanie czasów reakcji, kompletność powiadomień, poprawność decyzji oraz jakość dokumentacji. Stwierdzone nieprawidłowości traktuje się jak zalecenia po incydencie.
- 11.5. Szkolenia pracowników. Każdy pracownik przechodzi szkolenie z rozpoznawania i zgłaszania incydentów przy zatrudnieniu, w ciągu 30 dni, oraz powtarzają je co roku.
 - 11.5.1. Szkolenie obejmuje przykłady wiadomości wyłudzających dane, zasady zgłaszania zdarzeń oraz skutki zaniechania zgłoszenia.
 - 11.5.2. Członkowie Zespołu przechodzą dodatkowe szkolenie specjalistyczne obejmujące narzędzia, zasady zabezpieczania dowodów i komunikacji w czasie incydu.
 - 11.5.3. Udział w szkoleniach rejestruje Jednostka kadr, a Jednostka bezpieczeństwa otrzymuje raport o osobach, które nie ukończyły szkolenia w terminie.
- 11.6. Scenariusze ćwiczeń. Scenariusze ćwiczeń przygotowuje Jednostka bezpieczeństwa w oparciu o rzeczywiste zagrożenia i wnioski z incydentów. Każdy scenariusz opisuje:
 - 11.6.1. cel ćwiczenia i oczekiwane zachowania uczestników;
 - 11.6.2. przebieg zdarzeń w czasie, w tym momenty podawania uczestnikom nowych informacji;
 - 11.6.3. role uczestników oraz obserwatorów;
 - 11.6.4. kryteria oceny wykonania ćwiczenia.
- 11.7. Zakres tematyczny. W cyklu rocznym ćwiczenia obejmują przynajmniej: atak szyfrujący dane, wyciek danych osobowych, niedostępność systemu centralnego, przejęcie konta

uprzywilejowanego, incydent u kluczowego dostawcy oraz kampanię wyłudającą dane Klientów.

- 11.8. Sprawozdanie z testów. Po każdym ćwiczeniu Jednostka bezpieczeństwa sporządza sprawozdanie, które obejmuje ocenę wykonania, listę zaobserwowanych braków i propozycje zmian.
- 11.9. Wykorzystanie sprawozdań. Zalecenia ze sprawozdań wpisuje się do planu działań na takich samych zasadach jak zalecenia po incydentach. Zbiornicze wyniki testów Jednostka bezpieczeństwa przedstawia Zarządowi raz w roku, wraz z oceną gotowości Banku do reagowania na incydenty.
- 11.10. Testy z udziałem dostawców. W umowach z kluczowymi dostawcami Bank zachowuje prawo do udziału w testach awaryjnych dostawcy oraz do żądania wyników testów odtwarzania usług.
 - 11.10.1. Wyniki testów dostawcy ocenia właściciel umowy wspólnie z Jednostką bezpieczeństwa.
 - 11.10.2. Negatywne wyniki testów skutkują wezwaniem dostawcy do przekazania planu naprawczego w wyznaczonym terminie.

12. Przypadki szczególne

Poniżej opisano sytuacje, w których postępowanie według zasad ogólnych wymaga modyfikacji. Pozostałe postanowienia procedury stosuje się odpowiednio.

Zasady wspólne dla przypadków szczególnych:

- 1) w przypadku wątpliwości co do tego, który tryb obowiązuje, stosuje się tryb bardziej rygorystyczny;
 - 2) kierownik incyduentu może odstąpić od kolejności czynności określonej w procedurze, jeżeli wymaga tego ochrona Klientów lub ich środków; odstąpienie i jego uzasadnienie odnotowuje w dzienniku zdarzeń;
 - 3) w przypadku jednoczesnego wystąpienia kilku incydentów priorytet nadaje się według poziomu ważności, a przy tym samym poziomie — według liczby dotkniętych Klientów.
- 12.1. Awaria systemu płatności lub rozliczeń. W razie awarii, która uniemożliwia realizację przelewów lub rozliczeń, Jednostka operacji:
 - 12.1.1. ustala listę zleceń nierealizowanych, w tym zleceń natychmiastowych oraz z terminami, których niedotrzymanie powoduje dla Klienta dodatkowe skutki;
 - 12.1.2. po przywróceniu systemu realizuje zlecenia w kolejności ich złożenia, z uwzględnieniem priorytetów;
 - 12.1.3. informuje Jednostkę zgodności o terminie wznowienia, aby oceniła, czy incydent podlega zgłoszeniu organowi nadzoru jako incydent poważny.
 - 12.2. Skutki dla Klientów. Opłaty i odsetki naliczone Klientom w wyniku opóźnienia spowodowanego awarią Bank zwraca z urzędu.
 - 12.3. Incydent u kluczowego dostawcy. Jeżeli dostawca popowiadania o incydencie w swoich systemach lub awarii usługi istotnej dla Banku, Jednostka bezpieczeństwa:
 - 12.3.1. rejestruje incydent i klasyfikuje go według wpływu na usługi Banku;

- 12.3.2. ustala, czy dane Banku lub Klientów zostały ujawnione lub utracone;
- 12.3.3. w przypadku potrzeby uruchamia rozwiązania zastępcze przewidziane w planie ciągłości działania, w tym przejście na alternatywnego dostawcę lub tryb ręczny;
- 12.3.4. w przypadku incydentu poważnego dotyczącego usługi zleconej na zewnątrz informuje organ nadzoru, jak dla incydentu własnego.
- 12.4. Masowa kompromitacja kart. Gdy organizacja kartowa, operator systemu płatności lub sprzedawca popowiadamia Bank o kompromitacji numerów kart, Jednostka operacji:
 - 12.4.1. określa listę dotkniętych kart i czasowo je blokuje, niezwłocznie wydając Klientom nowe karty bez opłat;
 - 12.4.2. monitoruje transakcje dokonane kartami ujętymi na liście przed ich zablokowaniem;
 - 12.4.3. uruchamia procedurę zwrotu nieautoryzowanych transakcji, zgodnie z terminami wynikającymi z przepisów o usługach płatniczych.
- 12.5. Komunikacja z Klientami. Klientów, których karty zablokowano, informuje się o przyczynie blokady i o sposobie odbioru nowej karty. Informację można przekazać telefonicznie, wiadomością SMS lub w bankowości elektronicznej.
- 12.6. Atak odmowy usługi. W razie ataku przeciążeniowego na kanały elektroniczne Jednostka informatyki:
 - 12.6.1. uruchamia mechanizmy filtrowania ruchu i, w przypadku potrzeby, usługę ochrony udostępnioną przez operatora łączy;
 - 12.6.2. przekierowuje ruch Klientów do zapasowych punktów dostępu, o ile takie istnieją;
 - 12.6.3. zbiera dane o źródłach i charakterze ruchu na potrzeby analizy i zawiadomienia o przestępstwie.
- 12.7. Komunikacja podczas ataku. Jednostka komunikacji informuje Klientów o utrudnieniach w dostępie do bankowości elektronicznej i o możliwości skorzystania z placówek i infolinii. Komunikat nie obejmuje informacji o zastosowanych zabezpieczeniach.

13. Kontrola i nadzór

Stosowanie procedury podlega kontroli w ramach systemu kontroli wewnętrznej Banku, zgodnie z wymogami wynikającymi z przepisów prawa bankowego — zob. ustawa z dnia 29 sierpnia 1997 r. – Prawo bankowe (Dz. U. 2024 poz. 1646).

- 1. Kontrola obejmuje:
 - 1) kontrolę funkcjonalną, czyli bieżącą weryfikację kompletności wpisów w Rejestrze przez Jednostkę bezpieczeństwa (co miesiąc);
 - 2) kontrolę Jednostki zgodności, czyli ocenę dotrzymywania terminów zawiadomień dla organów zewnętrznych (co kwartał);
 - 3) audyt wewnętrzny, czyli niezależną ocenę adekwatności i skuteczności procedury, prowadzoną przez Jednostkę audytu zgodnie z planem audytów.

2. Wskaźniki monitorowane w ramach nadzoru nad procedurą to w szczególności:

- 1) liczba incydentów w podziale na poziomy ważności i kategorie;
- 2) średni czas wykrycia, klasyfikacji i zamknięcia incydu;
- 3) odsetek incydentów, w których dotrzymano czasu pierwszej reakcji;
- 4) odsetek zawiadomień przekazanych w terminie;
- 5) liczba przeterminowanych zaleceń po incydentach.

Jednostka bezpieczeństwa przedstawia Zarządowi kwartalne sprawozdanie z incydentów, a w razie incydu krytycznego — niezwłoczną informację. Nieprawidłowości stwierdzone w kontroli są podstawą do zaleceń, których wykonanie monitoruje Jednostka zgodności.

Jednostka bezpieczeństwa prowadzi wskaźniki ryzyka (KRI) dotyczące incydentów, dla których Zarząd ustala poziomy ostrzegawczy. Przekroczenie poziomu ostrzegawczego wymaga:

- 1) pisemnego wyjaśnienia przyczyn przez właściciela procesu;
- 2) planu działań naprawczych z terminami;
- 3) informacji w najbliższym sprawozdaniu dla Zarządu.

Wskaźniki obejmują m.in. liczbę incydentów krytycznych w kwartale, średni czas wykrycia, odsetek niedotrzymanych terminów zawiadomień oraz liczbę incydentów powtarzających się.

Jednostka zgodności raz na kwartał wykonuje kontrolę próbną, która obejmuje:

- 1) wybór losowej próby incydentów z Rejestru i sprawdzenie kompletności ich dokumentacji;
- 2) sprawdzenie, czy poziom ważności został nadany prawidłowo;
- 3) sprawdzenie dotrzymania terminów zawiadomień dla organu nadzoru i organu ochrony danych;
- 4) ocenę, czy zalecenia z przeglądu zostały zrealizowane.

Wyniki kontroli przedstawia się dyrektorowi Jednostki bezpieczeństwa, który odpowiada za usunięcie nieprawidłowości.

Raz w roku Jednostka bezpieczeństwa dokonuje samooceny poziomu rozwoju procesu obsługi incydentów, porównując go z uznanymi standardami zarządzania incydentami. Wyniki samooceny, wraz z wskazanymi obszarami do poprawy, przedstawia Zarządowi. Obszary do poprawy wprowadza się do planu działań na kolejny rok.

Poza samooceną Jednostka audytu ocenia w cyklu audytowym, czy procedura jest stosowana w całym Banku, w tym w oddziałach i jednostkach zależnych.

14. Dokumentacja i archiwizacja

Dokumentację incydu tworzą: wpis w Rejestrze, karta incydu (F-BEZ-02), dziennik zdarzeń z pokoju operacyjnego, protokoły zabezpieczenia dowodów (F-BEZ-04), kopie zawiadomień i korespondencji z organami zewnętrznymi oraz raporty z przeglądu

(F-BEZ-05).

Dokumentację przechowuje się w następujący sposób:

- 1) w postaci elektronicznej, w systemie zgłoszeń i w repozytorium dokumentów Jednostki bezpieczeństwa, z dostępem ograniczonym do osób uprawnionych;
- 2) przez okres 10 lat od zamknięcia incydu, a w przypadku toczących się postępowań — do ich prawomocnego zakończenia;
- 3) z zabezpieczeniem przed zmianą — poprawki wpisów dokonuje się przez dopisek, bez usuwania poprzedniej treści.

Po upływie okresu przechowywania dokumentację niszczy się w sposób uniemożliwiający jej odtworzenie, za zgodą Jednostki prawnej, a protokół zniszczenia dołącza się do ewidencji dokumentów. Dokumentacja zawierająca tajemnicę bankową może być udostępniona jedynie na zasadach określonych w przepisach prawa bankowego.

Dane osobowe Klientów wykorzystuje się wyłącznie w zakresie niezbędnym do realizacji zadań opisanych w procedurze, zgodnie z przepisami o ochronie danych osobowych (zob. ustawa z dnia 10 maja 2018 r. o ochronie danych osobowych (Dz. U. 2019 poz. 1781)) oraz z zasadą minimalizacji danych.

Pracownik wykonujący czynności objęte procedurą jest obowiązany:

- 1) zabezpieczać dokumenty i dane przed dostępem osób nieupoważnionych;
- 2) nie udostępniać danych poza Bank bez podstawy prawnej;
- 3) niezwłocznie zgłaszać każde podejrzenie naruszenia ochrony danych: inspektorowi ochrony danych (Inspektor Ochrony Danych) oraz jednostce bezpieczeństwa (Departament Bezpieczeństwa).

Wnioski osób, których dane dotyczą, przekazuje się do inspektora ochrony danych (Inspektor Ochrony Danych, iod@bank.example); odpowiedź jest udzielana bez zbędnej zwłoki, nie później niż w terminie miesiąca od dnia otrzymania wniosku.

15. Postanowienia końcowe

Procedura wchodzi w życie z dniem 1 listopada 2022 r. i obowiązuje wszystkich pracowników Banku. Z tym dniem traci moc poprzednia wersja procedury obsługi incydentów.

Właścicielem procedury jest Departament Bezpieczeństwa, który przegląda jej treść przynajmniej raz w roku oraz po każdym incydencie krytycznym i po każdej zmianie przepisów lub wytycznych organu nadzoru wpływającej na jej treść.

Załączniki stanowią nierozdzielalną część procedury. Wzory formularzy wskazanych w procedurze udostępnia właściciel procedury w repozytorium dokumentów wewnętrznych.

Zmiany procedury wprowadza się w trybie przewidzianym dla jej pierwotnego przyjęcia. Projekt zmiany przygotowuje właściciel procedury, a opiniuje Departament Zgodności oraz, w razie potrzeby, Departament Prawny.

Każda zmiana musi zawierać:

- 1) wskazanie nowej wersji i daty jej wejścia w życie;
- 2) zwięzły opis zmienionych postanowień wraz z uzasadnieniem;
- 3) wzmiankę o konieczności przeszkolenia pracowników.

Poprzednie wersje archiwizuje się i udostępnia na żądanie komórki ds. zgodności (Departament Zgodności). Pracownicy są informowani o zmianie przed dniem jej wejścia w życie.

Kontakt z Klientem prowadzi się wyłącznie kanałami opisanymi w umowie lub w ustaleniach z Klientem. Dane teleadresowe Banku podawane w korespondencji muszą być zgodne z danymi: adres ul. Przykładowa 1, 00-001 Warszawa, infolinia 800 000 001, strona <https://bank.example>.

W rozmowie z Klientem pracownik:

- 1) przedstawia się i nazwę Banku;
- 2) potwierdza tożsamość Klienta metodą przewidzianą w procedurach bezpieczeństwa;
- 3) nie prosi o podanie haseł, kodów jednorazowych ani numeru PIN.

Sprawy wymagające eskalacji przekazuje się do jednostki właściwej (Departament Obsługi Klienta), a podejrzania nadużyć — do jednostki bezpieczeństwa (Departament Bezpieczeństwa).

Załącznik nr 1

Macierz klasyfikacji incydentów i wzór karty incyduentu

Macierz pozwala przypisać incydent do poziomu ważności. Gdy incydent spełnia kryteria co najmniej dwóch poziomów, przyjmuje się poziom najwyższy.

Kryterium	Krytyczny	Wysoki	Średni
Liczba dotkniętych Klientów	ponad 1 000 Klientów	od 100 do 1 000 Klientów	mniej niż 100 Klientów
Czas niedostępności usługi	dłużej niż 2 godziny	od 30 minut do 2 godzin	krócej niż 30 minut
Potencjalna strata finansowa	powyżej 500 000,00 zł	powyżej 50 000,00 zł	poniżej 50 000,00 zł
Dane osobowe	ujawnienie danych o wysokim ryzyku lub danych szczególnych kategorii	ujawnienie danych zwykłych bez ryzyka wysokiego	brak ujawnienia
Pierwsza reakcja — do	15 minut	1 godziny	4 godzin
Obsługa	Zespół, powiadomienie członka Zarządu	Zespół, powiadomienie dyrektorów	dyżurny i właściwa jednostka

Incydent o poziomie niskim obsługuje dyżurny w czasie do 2 dni roboczych.

Wzór karty incyduentu

Karta incyduentu (F-BEZ-02) zawiera następujące pola:

Pole	Zawartość
Numer incyduentu	numer przypisany w Rejestrze
Data i godzina wykrycia	moment wykrycia oraz zgłoszenia
Zgłaszający	imię i nazwisko, jednostka, kanał zgłoszenia
Opis zdarzenia	co się stało, jakich systemów lub procesów dotyczy
Kategoria i poziom ważności	kategoria incyduentu, poziom nadany i ewentualne zmiany z godziną
Kierownik incyduentu	imię i nazwisko, skład Zespołu
Skutki	liczba Klientów, wartość operacji, czas niedostępności
Podjęte działania	chronologiczny wykaz czynności z godzinami
Zawiadomienia	adresaci, terminy, numery zawiadomień
Przyczyna źródłowa	ustalona przyczyna lub wzmianka o braku ustaleń
Zalecenia	zalecenia, osoby odpowiedzialne, terminy

Wykaz terminów

Czynność	Termin
Zgłoszenie zdarzenia przez pracownika	do 30 minut od zauważenia
Klasyfikacja incyduentu	do 2 godzin od zarejestrowania zgłoszenia
Zawiadomienie wstępne dla organu nadzoru	do 6 godzin od zaklasyfikowania incyduentu jako poważnego
Zawiadomienie pośrednie	do 72 godzin od zawiadomienia wstępnego
Raport końcowy	do 1 miesiąca od zawiadomienia pośredniego
Zgłoszenie naruszenia danych osobowych	do 72 godzin od stwierdzenia naruszenia
Powiadomienie Klientów	do 24 godzin od potwierdzenia, że incydent ich dotyczy
Przegląd po incydencie	do 14 dni od zakończenia obsługi incyduentu

Wykaz kontaktów alarmowych

Funkcja	Kontakt
Dyżurny Jednostki bezpieczeństwa	telefon 800 000 040, adres e-mail incydenty@bank.example
Inspektor	adres e-mail iod@bank.example
Infolinia dla Klientów	800 000 001 (codziennie przez całą dobę)
Zastrzeganie instrumentów płatniczych	800 000 002
Dyżurny Jednostki informatyki	numer służbowy zgodny z aktualnym harmonogramem dyżurów
Organ nadzoru	kanał wyznaczony przez organ nadzoru dla zawiadomień o incydentach poważnych

Wzór komunikatu dla Klientów

Wzór stanowi punkt wyjścia; treść każdego komunikatu uzgadnia kierownik incyduentu z Jednostką komunikacji.

Drodzy Klienci, informujemy, że w dniu {data} Bank wykrył zdarzenie, które mogło wpłynąć na {rodzaj usługi}. Podjęliśmy działania, aby zabezpieczyć Państwa środki i dane. Prosimy o zmianę hasła do bankowości elektronicznej i o ostrożność wobec wiadomości podszywających się pod Bank. Bank nigdy nie prosi o podanie pełnych danych uwierzytelniających. W razie pytań prosimy o kontakt z infolinią 800 000 001.

Załącznik nr 2

Lista kontrolna obsługi incydentu

Listę wypełnia kierownik incydentu (lub dyżurny — dla incydentów średnich i niskich) i dołącza do karty incydentu.

- ☐ Zgłoszenie zarejestrowane w Rejestrze i potwierdzone osobie zgłaszającej.
- ☐ Poziom ważności nadany w ciągu 2 godzin od zgłoszenia.
- ☐ Wyznaczono kierownika incydentu; w razie potrzeby powołano Zespół.
- ☐ Otwarto pokój operacyjny i prowadzony jest dziennik zdarzeń.
- ☐ Zabezpieczono materiał dowodowy, a protokół F-BEZ-04 wypełniono.
- ☐ Podjęto działania ograniczające skutki, a ich wpływ na Klientów oceniono.
- ☐ Jednostka zgodności i Inspektor ocenili obowiązki wobec podmiotów zewnętrznych.
- ☐ Zawiadomienie wstępne dla organu nadzoru przekazano w terminie 6 godzin (jeżeli dotyczy).
- ☐ Naruszenie ochrony danych zgłoszono w terminie 72 godzin (jeżeli dotyczy).
- ☐ Klientów poinformowano w terminie 24 godzin (jeżeli dotyczy).
- ☐ Usunięto przyczynę, a usługi przywrócono i zweryfikowano.
- ☐ Skorygowano błędne księgowania i zwrócono nieautoryzowane transakcje.
- ☐ Zawiadomienie pośrednie i raport końcowy przekazano w terminach (jeżeli dotyczy).
- ☐ Przegląd po incydencie przeprowadzono w terminie 14 dni, a zalecenia wpisano do planu działań.
- ☐ Incydent zamknięto w Rejestrze.